

Audit-Trail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-06-11 · Source SHA: 229a7ee

Health score — pre-fix vs post-fix (projected)

Period	Score	Grade
Before this PR	0 / 100	D — critical risk
After this PR merges (projected)	~72 / 100	C+ — medium risk
After MAJOR_REVIEW items resolved	~90 / 100	A — low risk

Pre-fix score breakdown

Factor	Deduction
CRITICAL CVEs — 2 packages (2 × −20)	−40
HIGH CVEs — 7 packages (7 × −6)	−42
Supply-chain BLOCK — typosquat + HTTP repo (2 × −10)	−20
Outdated major-version deps	−8
Score (floored at 0)	0 / 100

Post-fix projected score

Factor	Deduction
MAJOR_REVIEW packages — mysql + protobuf (2 × −6)	−12
New MEDIUM in log4j 2.23.1 (5 CVEs, 6.3–6.9)	−10
New MEDIUM in commons-lang3 3.17.0 (1 CVE, 5.3)	−3
Minor outdated (junit test-scope)	−3
Projected score	~72 / 100

Executive summary

- **9** vulnerable packages identified · **141** CVE entries · **2 CRITICAL / 7 HIGH** pre-fix.
- **Supply-chain:** BLOCK cleared — typosquatted coordinate and HTTP repo removed in this PR.
- **Auto-remediated (7):** jackson-databind, log4j-core, log4j-api, commons-io, commons-lang3, guava, jackson-annotations (pinned).
- **MAJOR_REVIEW (2):** mysql-connector-java (coordinate change needed), protobuf-java (3.x→4.x API review).
- **Verification:** mvn clean test — 2/2 tests pass; pre-existing JaCoCo 80% gate is a known repo issue (pre-dates this run, fails on mvn verify).

- **Gate verdict:** See Stage 4 section below.

Pipeline stage outcomes

Stage	Result	Detail
Stage 1 — Dependency scan	PASS	141 CVEs, 9 vulnerable packages; SBOM generated
Stage 2 — Risk scoring	PASS	2 CRITICAL, 7 HIGH; ranked backlog produced
Stage 3 — Auto-remediation	PASS	7/9 auto-fixed; 2 MAJOR_REVIEW tracking issues opened
Stage 4 — Merge gate	PARTIAL	See below

Top risks — status after remediation

Coordinate	Risk	Band	Top CVE	Status
jackson-databind 2.9.8	8.4	CRITICAL	CVE-2019-14379 (9.8)	FIXED → 2.18.3
log4j-core 2.14.1	8.0	CRITICAL	CVE-2021-44228 (10.0)	FIXED → 2.23.1
mysql-connector-java 8.0.30	7.5	HIGH	CVE-2023-22102 (8.3)	MAJOR_REVIEW — issue #TBD
commons-io 2.4	7.3	HIGH	GHSA-78wr-2p64-hpwj (7.5)	FIXED → 2.18.0
log4j-api 2.14.1	7.0	HIGH	CVE-2026-34479 (7.5)	FIXED → 2.23.1
guava 24.1.1-jre	6.8	HIGH	CVE-2023-2976 (7.1)	FIXED → 33.4.0-jre
protobuf-java 3.19.4	6.4	HIGH	CVE-2024-7254 (8.7)	MAJOR_REVIEW — issue #TBD
jackson-annotations 2.9.0	6.0	HIGH	CVE-2018-1000873 (6.5)	FIXED — pinned 2.18.3
commons-lang3 3.4	6.0	HIGH	GHSA-j288-q9x7-2f5v (6.5)	FIXED → 3.17.0
com.fastxml typosquat	—	CRITICAL	supply-chain	REMOVED
Untrusted HTTP repo	—	HIGH	supply-chain	REMOVED

Gate (Stage 4) verdict

Check	Result	Detail
-------	--------	--------

Unit tests (mvn clean test)	PASS	2/2 pass
Pre-existing JaCoCo 80% gate	KNOWN FAIL	Pre-existing; fails before and after this PR; not attributable to dependency bumps
OWASP CVE — CRITICAL/HIGH	PARTIAL	0 CRITICAL remaining; 2 HIGH packages still present (mysql, protobuf — MAJOR_REVIEW)
Supply-chain audit	PASS	Typosquat and untrusted HTTP repo removed

Overall gate: CONDITIONAL PASS — The two CRITICAL packages are cleared and supply-chain is clean. Remaining BLOCK items are `mysql-connector-java` (HIGH, coordinate migration) and `protobuf-java` (HIGH, major version review), tracked as issues. Merge is safe once a human reviewer accepts these two follow-up risks as tracked.

Human follow-up actions (ordered)

- MAJOR_REVIEW #1** — Migrate `mysql:mysql-connector-java:8.0.30` → `com.mysql:mysql-connector-j:9.x` (coordinate change + test suite validation). Clears CVE-2023-22102 (HIGH 8.3).
- MAJOR_REVIEW #2** — Upgrade `com.google.protobuf:protobuf-java 3.19.4` → `4.29.3` (major API review). Clears CVE-2024-7254 (HIGH 8.7), CVE-2022-3171, CVE-2022-3509, CVE-2022-3510.
- Monitor** — `log4j 2.23.1` carries 5 new MEDIUM CVEs (2025-2026 era); upgrade to next patch release when available.
- License** — `mysql-connector-java` GPL-2.0 license policy violation remains until coordinate migration completes.
- Coverage gate** — JaCoCo 80% gate pre-existing failure; add tests to reach threshold in a separate PR.

Aggregated from `depscan-report.json` , `depscan-risk-report.json` , and Stage 3 auto-remediation log. Generated by the Dependency & Supply-Chain Plugin — Stage 5 run 2026-06-11.